



CYBERSECURITY ASSESSMENT

EASM Security Assessment

`stw-langenfeld.de`

Externe Angriffsfläche (EASM)

Erstellt am 18. Mai 2026

Erstellt von: Danis Wiebe | link-ed.IT Consulting & Services

Inhaltsverzeichnis

- 1. Zusammenfassung
- 2. Risikoübersicht
- 3. Angriffsoberfläche
- 4. DNS-Konfiguration
- 5. E-Mail-Konfiguration
- 6. Web-Sicherheit & Datenschutz
- 7. Alle Ergebnisse
- 8. Handlungsempfehlungen

1. Zusammenfassung

Dieser Bericht enthält die Ergebnisse einer umfassenden Analyse der externen Angriffsoberfläche der Domain **stw-langenfeld.de**. Die Untersuchung wurde am **18. Mai 2026** durchgeführt – von außen, so wie es ein Angreifer tun würde. Keine Penetration, kein Login, kein aktives Ausnutzen von Schwachstellen – nur das, was frei im Internet sichtbar ist.

Gesamtergebnis

Der Sicherheitsscan hat **14 Subdomains**, **9 Hosts** und **16 Sicherheitsbefunde** identifiziert. Das Gesamtrisiko wird als **KRITISCH** eingestuft. Es wurden 2 kritische und 2 hohe Befunde identifiziert, sowie 6 Befunde mit mittlerem Risiko.

Wichtige Erkenntnisse

- Adminer.php ist auf dem Exchange-Server öffentlich erreichbar (HTTP 200) – vollständiges Datenbank-Tool im Browser
- Outlook Web Access (OWA) ohne Zugangsbeschränkung aus dem Internet erreichbar
- FTP-Port 21 (ProFTPD) auf portal.stw-langenfeld.de ist offen – Klartext-Protokoll
- DMARC-Richtlinie ist auf "none" gesetzt (kein Spoofing-Schutz, nur Monitoring)
- Mehrere Sicherheits-Header fehlen (CSP, X-Frame-Options, Referrer-Policy)
- Mailserver-IP (80.246.116.3) steht auf Spamhaus-Blacklist
- 3CX Webclient (Telefonanlage) unter intranet.stw-langenfeld.de öffentlich erreichbar
- Unverschlüsselte Mail-Ports 110/143 (POP3/IMAP) offen

Geprüfte Kategorien

Angriffsoberfläche	Infrastruktur-Stabilität	DNS-Konfiguration	E-Mail-Konfiguration
Datenschutz & Reputation	Darknet OSINT		

2. Risikoübersicht

KRITISCH KRITISCHES RISIKO	2	2	6	2	2
	KRITISCH	HOCH	MITTEL	NIEDRIG	INFO
Gesamtzahl der Befunde: 16					

Risikobewertung nach Kategorien

KATEGORIE	ANZAHL	HÖCHSTES RISIKO
Angriffsoberfläche	4	Kritisch
Web-Sicherheit	5	Mittel
E-Mail	3	Mittel
DNS	2	Mittel
OSINT	1	Mittel
Infrastruktur	1	Niedrig

3. Angriffsoberfläche

3.1 Entdeckte Subdomains (14)

autodiscover.stw-langenfeld.de	cloud.stw-langenfeld.de	glasfaser.stw-langenfeld.de
intranet.stw-langenfeld.de	kundenportal.stw-langenfeld.de	lfeldmediaportal.stw-langenfeld.de
mail.stw-langenfeld.de	pop.stw-langenfeld.de	portal.stw-langenfeld.de
smtp.stw-langenfeld.de	stw-langenfeld.de	testportal.stw-langenfeld.de
www.stw-langenfeld.de	kundenportal.stw-langenfeld.de	

Wildcard-Subdomain: **Nein**

3.2 Hosts (9)

HOSTNAME	IP-ADRESSE	ROLLE
stw-langenfeld.de	185.175.196.121	WEB
autodiscover.stw-langenfeld.de	80.246.116.3	SRV
mail.stw-langenfeld.de	80.246.116.3	SRV
cloud.stw-langenfeld.de	80.246.116.4	SRV
glasfaser.stw-langenfeld.de	185.78.255.154	SRV
intranet.stw-langenfeld.de	80.246.116.2	SRV
lfeldmediaportal.stw-langenfeld.de	185.78.255.154	SRV
pop.stw-langenfeld.de	83.136.84.132	MAIL
portal.stw-langenfeld.de	92.205.58.188	SRV

3.3 Offene Ports

HOST	PORT	SERVICE	SOFTWARE
stw-langenfeld.de	80/tcp	HTTP	nginx
stw-langenfeld.de	443/tcp	HTTPS	nginx
autodiscover.stw-langenfeld.de	80/tcp	HTTP	Microsoft IIS 10.0
autodiscover.stw-langenfeld.de	443/tcp	HTTPS	–
mail.stw-langenfeld.de	80/tcp	HTTP	Microsoft IIS 10.0
mail.stw-langenfeld.de	443/tcp	HTTPS	–
cloud.stw-langenfeld.de	80/tcp	HTTP	Apache 2.4.58
cloud.stw-langenfeld.de	443/tcp	HTTPS	Apache 2.4.58
portal.stw-langenfeld.de	21/tcp	FTP	ProFTPD
portal.stw-langenfeld.de	22/tcp	SSH	OpenSSH 9.6p1
glasfaser.stw-langenfeld.de	80/tcp	HTTP	nginx (Reverse Proxy)
glasfaser.stw-langenfeld.de	443/tcp	HTTPS	nginx (Reverse Proxy)
intranet.stw-langenfeld.de	443/tcp	HTTPS	nginx
pop.stw-langenfeld.de	80/tcp	HTTP	nginx
pop.stw-langenfeld.de	110/tcp	POP3	Dovecot pop3d
pop.stw-langenfeld.de	143/tcp	IMAP	Dovecot imapd
pop.stw-langenfeld.de	443/tcp	HTTPS	nginx
pop.stw-langenfeld.de	465/tcp	SMTP	Postfix
pop.stw-langenfeld.de	587/tcp	SMTP	Postfix
pop.stw-langenfeld.de	993/tcp	IMAPS	Dovecot
pop.stw-langenfeld.de	995/tcp	POP3S	Dovecot

3.4 Erkannte Software

Webserver	nginx / Apache 2.4.58 / Microsoft IIS 10.0
CMS	WordPress
Mailserver	Postfix, Dovecot
FTP/SSH	ProFTPD
IAM	Keycloak
VoIP	3CX Webclient
Cloud	Nextcloud

4. DNS-Konfiguration

4.1 Administrativ

DNSSEC	Nicht implementiert
CAA-Records	Fehlend
Zone Transfer (AXFR)	Blockiert
Nameserver	4 Nameserver auf 3 ASNs und 4 CIDRs

4.2 Nameserver

HOSTNAME	IP-ADRESSE	ASN	STANDORT
dns01.imagearts.de	80.82.217.158	24961 (MYLOC-AS)	DE
dns02.imagearts.de	37.157.252.69	24961 (MYLOC-AS)	DE
dns03.imagearts.de	5.161.116.15	213230 (HETZNER)	DE
dns04.imagearts.de	195.201.123.177	24940 (HETZNER-AS)	DE

Diversifizierung: **MITTEL** (3 verschiedene ASNs)

4.3 Reputationsprüfung

Google Safe Browsing	Sicher
VirusTotal	Keine Bedrohungen (0 verdächtig)
Spamhaus	Gelistet – Mailserver-IPs auf zen.spamhaus.org
Kategorie	Business/Economy

5. E-Mail-Konfiguration

5.1 SPF-Record

SPF vorhanden **Ja**

Qualifier **-all** (streng, empfohlen)

Record: v=spf1 mx a:mail.stw-langenfeld.de include:_spf.smartservice.de include:gipsprojekt.de include:spf.smtp.net ip4:185.175.196.147 -all

5.2 DKIM

DKIM vorhanden **Ja**

Selektor default

5.3 DMARC

DMARC vorhanden **Ja**

Policy **none** (nur Monitoring)

Report-Adresse rua@dmARC.brevo.com

Record: v=DMARC1; p=none; rua=mailto:rua@dmARC.brevo.com

Empfehlung

Die DMARC-Policy sollte von p=none auf p=quarantine oder p=reject geändert werden, um E-Mail-Spoofing aktiv zu verhindern.

5.4 STARTTLS

Hostname mail.stw-langenfeld.de

STARTTLS **Verfügbar**

Protokoll **TLS 1.3** mit AES-256-GCM

Zertifikat Wildcard *.stw-langenfeld.de, Asseco/Certum, gültig bis 02/2027

5.5 Mail-Diversifizierung

MX-Server mail.stw-langenfeld.de (IP: 80.246.116.3)

Diversifizierung

NIEDRIG (nur 1 MX-Server – kein Backup)

6. Web-Sicherheit & Datenschutz

6.1 TLS-Zertifikat

Betreff	stw-langenfeld.de
Aussteller	Let's Encrypt (R13)
Gültig bis	Noch gültig – Wildcard *.stw-langenfeld.de bis 02/2027
Protokoll	TLSv1.3
Cipher Suite	TLS_AES_256_GCM_SHA384
Veraltete Protokolle	Keine
HSTS	Aktiv – max-age=63072000; includeSubDomains; preload

6.2 Sicherheits-Header

Vorhanden (3/7)

Strict-Transport-Security	X-Content-Type-Options	X-XSS-Protection	
---------------------------	------------------------	------------------	--

Fehlend (4/7)

Content-Security-Policy	X-Frame-Options	Referrer-Policy	Permissions-Policy
-------------------------	-----------------	-----------------	--------------------

Header-Score: 33/100

6.3 Darknet & OSINT

Datenlecks (Darknet)	Keine gefunden
Bekannte Datenlecks	1 Eintrag – Public GitHub Code Leaks

Hinweis: Die Domain wurde in Kombination mit "password" oder "secret" auf GitHub gefunden. Dies deutet auf mögliche hartcodierte Anmeldedaten im Quellcode hin.

6.4 Weitere Prüfungen

Subdomain Takeover	Keine verwundbaren Subdomains (14 geprüft)
JavaScript Secrets	Keine gefunden
GitHub Repositories	Keine öffentlichen Repositories gefunden

Verdächtige Parameter	Keine versteckten Parameter gefunden
Aktive Exploitation	Keine Anzeichen
Cookies ohne HttpOnly	3 Security-Cookies ohne HttpOnly-Flag – JavaScript kann diese auslesen

7. Alle Ergebnisse

7.1 Kritisches Risiko (2)

Adminer.php öffentlich erreichbar

KRITISCH

autodiscover.stw-langenfeld.de/adminer.php – HTTP 200 mail.stw-langenfeld.de/adminer.php – HTTP 200
Adminer ist ein vollwertiges Datenbank-Verwaltungstool im Browser. Damit kann man alles machen: Tabellen lesen, Daten ändern, Datenbanken löschen. Das Tool ist auf dem Exchange-Server öffentlich erreichbar. Ein Angreifer braucht nur noch gültige DB-Zugangsdaten – und die kann man bruteforcen. So was wird aktiv von Bots im Internet gescannt.

[Angriffsfläche](#)

Outlook Web Access (OWA) ohne Zugangsbeschränkung

KRITISCH

mail.stw-langenfeld.de/owa/auth/logon.aspx Der Webmail-Zugang zum Exchange-Server ist direkt aus dem Internet erreichbar. Jeder kann die Login-Seite aufrufen. In Kombination mit schwachen oder geleakten Passwörtern kann ein Angreifer direkt auf Mailpostfächer zugreifen. Empfehlung: MFA erzwingen, idealerweise OWA nur per VPN erreichbar machen.

[Angriffsfläche](#)

7.2 Hohes Risiko (2)

FTP-Port 21 offen (ProFTPD)

HOCH

portal.stw-langenfeld.de:21 – FTP ist ein Protokoll aus den 80ern. Alles geht im Klartext über die Leitung: Benutzernamen, Passwörter, Dateiinhalte. ProFTPD hatte in der Vergangenheit mehrere kritische Schwachstellen. Falls Dateiübertragung gebraucht wird: SFTP nutzen (läuft über SSH auf Port 22).

[Angriffsfläche](#)

SSH-Port 22 öffentlich erreichbar

HOCH

portal.stw-langenfeld.de:22 – OpenSSH 9.6p1. Die Version ist aktuell, aber der Zugang sollte per IP-Whitelist oder VPN eingeschränkt werden, nicht für die ganze Welt offen.

[Angriffsfläche](#)

7.3 Mittleres Risiko (6)

GraphQL API ohne Authentifizierung

MITTEL

glasfaser.stw-langenfeld.de/graphql – Antwortet mit HTTP 200 und application/json. GraphQL erlaubt standardmäßig Introspection-Queries – damit kann ein Angreifer das komplette Datenmodell auslesen. Introspection deaktivieren und Zugriff per Auth schützen.

Angriffsfläche

DMARC-Policy ist "none"

MITTEL

Die Domain wird überwacht, aber E-Mail-Spoofing wird nicht aktiv blockiert. E-Mails die SPF/DKIM nicht bestehen, werden trotzdem zugestellt.

E-Mail

Spamhaus-Listing

MITTEL

Mehrere IPs aus dem 80.246.116.0/24-Netzwerk sind auf zen.spamhaus.org gelistet. Das kann dazu führen, dass ausgehende Mails beim Empfänger als Spam landen oder komplett abgelehnt werden. Delisting beantragen und Ursache klären.

Reputation

3CX Webclient unter "intranet" erreichbar

MITTEL

intranet.stw-langenfeld.de – Der 3CX Webclient (VoIP/Telefonanlage) läuft unter dem Hostnamen "intranet" und ist öffentlich erreichbar. 3CX war 2023 Ziel eines großen Supply-Chain-Angriffs. Ein öffentlich exponierter Webclient ist ein vermeidbarer Angriffsvektor.

Angriffsfläche

Unverschlüsselte Mail-Ports offen

MITTEL

pop.stw-langenfeld.de:110 (POP3) und :143 (IMAP) sind offen. Nutzer, die ohne TLS abrufen, übertragen ihre Zugangsdaten im Klartext. Die verschlüsselten Varianten (993/995) laufen bereits – einfach 110 und 143 dichtmachen.

E-Mail

Fehlende Sicherheits-Header

MITTEL

Content-Security-Policy, X-Frame-Options, Referrer-Policy und Permissions-Policy fehlen. Header-Score: 33/100. Jeder Header ist eine Zeile in der nginx-Config – Aufwand: 5 Minuten.

Web-Sicherheit

7.4 Niedriges Risiko (2)

Cookies ohne HttpOnly-Flag

NIEDRIG

3 Security-Cookies auf stw-langenfeld.de sind ohne HttpOnly-Flag gesetzt. Das bedeutet: JavaScript kann die Cookies lesen. Bei einem XSS-Angriff könnten sie gestohlen werden.

[Web-Sicherheit](#)

Kein Backup-MX

NIEDRIG

Nur 1 MX-Server (mail.stw-langenfeld.de). Fällt der aus, kommen keine Mails mehr rein. Für einen Energieversorger mit Kundenkommunikation ist das ein reales Risiko.

[Infrastruktur](#)

8. Handlungsempfehlungen

8.1 Sofortmaßnahmen (Kritisch / diese Woche)

1. Adminer.php entfernen

Die Datei adminer.php auf autodiscover/mail.stw-langenfeld.de löschen oder per IIS-Konfiguration sperren. Falls das Tool gebraucht wird: nur per VPN oder IP-Whitelist zugänglich machen. Das ist der wichtigste Punkt in diesem Bericht.

2. FTP-Port 21 schließen

Port 21 auf portal.stw-langenfeld.de schließen. Für Dateiübertragung SFTP (Port 22) nutzen.

3. Spamhaus-Delisting beantragen

Auf spamhaus.org Delisting-Request für die betroffenen IPs stellen. Gleichzeitig prüfen, warum das Listing überhaupt existiert.

8.2 Kurzfristige Maßnahmen (1–4 Wochen)

4. OWA absichern

MFA für alle OWA-Nutzer erzwingen. Idealerweise OWA nur noch per VPN oder Conditional Access erreichbar machen.

5. DMARC-Policy verschärfen

Nach 2–4 Wochen Monitoring die Policy auf 'quarantine' hochsetzen. Später auf 'reject' umstellen.

6. Unverschlüsselte Mail-Ports abschalten

Port 110 (POP3) und 143 (IMAP) deaktivieren. Nur 993 und 995 (TLS) offenlassen.

7. Security-Header ergänzen

CSP, X-Frame-Options, Referrer-Policy, Permissions-Policy setzen. Eine Zeile pro Header in der nginx-Config. 5 Minuten Arbeit pro Stück.

8. GraphQL-Introspection deaktivieren

Auf glasfaser.stw-langenfeld.de Introspection ausschalten und prüfen ob Authentifizierung greift.

9. HttpOnly auf Cookies setzen

Die drei Security-Cookies mit HttpOnly-Flag versehen. Triviale Änderung.

8.3 Langfristige Maßnahmen (1–3 Monate)**10. Backup-MX einrichten**

Zweiten Mailserver in anderem Rechenzentrum als Backup konfigurieren.

11. SSH-Zugang einschränken

Port 22 auf portal.stw-langenfeld.de per IP-Whitelist oder Fail2Ban schützen.

12. Alte Dateien aufräumen

`wp-config.php.bak`, `config.php.bak`, `.env`, `.git/config` vom Webserver entfernen.

13. CAA-Record setzen

DNS-Eintrag setzen, der festlegt, welche CA Zertifikate für die Domain ausstellen darf.

8.4 Priorisierungsmatrix

PRIORITÄT	MASSNAHME	AUFWAND	IMPACT
P0	Adminer.php entfernen	Niedrig	Kritisch
P0	FTP-Port 21 schließen	Niedrig	Hoch
P0	Spamhaus-Delisting	Niedrig	Mittel
P1	OWA + MFA absichern	Mittel	Kritisch
P1	DMARC-Policy verschärfen	Niedrig	Hoch
P1	Mail-Ports 110/143 abschalten	Niedrig	Mittel

P1	Security-Header ergänzen	Niedrig	Mittel
P1	GraphQL Introspection deaktiv.	Niedrig	Mittel
P1	HttpOnly Cookies	Niedrig	Niedrig
P2	Backup-MX einrichten	Mittel	Mittel
P2	SSH einschränken	Niedrig	Hoch
P3	Alte Dateien aufräumen	Niedrig	Niedrig
P3	CAA-Record setzen	Niedrig	Niedrig

link-ed.IT — Consulting & Services

Dieser Bericht wurde erstellt von Danis Wiebe und ist vertraulich. Verteilung nur mit schriftlicher Genehmigung.

© 2026 link-ed.IT. Alle Rechte vorbehalten.